

Table of Contents

Cisco Secure Workload — SOC 2 Compliance Framework

Reference Design | Enterprise Accounts

Version: 1.0 | **Standard:** SOC 2 Type II (AICPA Trust Services Criteria)

Reader's Guide

Who this is for. Service organizations preparing for or maintaining an annual SOC 2 Type II attestation, and the security or GRC teams who own the report.

Questions this reference design helps you answer:

- *Which Common Criteria controls can I evidence with continuous data rather than point-in-time samples? Type II auditors increasingly prefer the former. (CC6.1, CC6.6, CC7.2)*
- *When my auditor asks me to prove a segmentation control "operated effectively throughout the period", what does the artifact look like? (CC6.1, CC6.6)*
- *When a customer in due diligence asks "is workload X isolated from workload Y?", can I prove it from live data instead of a network diagram? (CC6.1, CC6.7)*
- *Are my privileged access changes producing the artifact format my auditor's evidence template expects? (CC6.2, CC6.3)*
- *For my Availability or Confidentiality TSC additions, what do I gain from workload-level telemetry that I don't get today?*

What you'll need. A defined trust boundary (system description), your current TSC selection, and your auditor's evidence request list or last year's PBC list.

Where to start. Section 1 for the TSC ↔ CSW capability map; sections 2–3 to design evidence collection; sections 4–5 if you're inside the audit window.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof	Enforce; quarterly	Ongoing

Phase	Goal	Key CSW actions	Typical duration
	between audits	export pack; ADM refresh every 90 days	

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: compliance:<framework>, data:<classification>, env:<tier>
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- CC6/CC7: continuous control operation vs. auditor sample windows
- Change and drift evidence from policy audit log + ADM refresh
- Customer due-diligence pack from repeatable quarterly exports

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

SOC 2 Type II audits evaluate whether security controls operated effectively over a defined period (typically 6–12 months). Cisco Secure Workload (CSW) can support evidence for selected **Security** Trust Services Criteria (TSC) and contribute technical inputs to **Availability**, **Confidentiality**, and **Processing Integrity** criteria through workload visibility, micro-segmentation, vulnerability exposure context, and forensic telemetry.

SOC 2 TSC to CSW Capability Map

Trust Services Criteria	CSW Capability
CC6 — Logical & Physical Access	Micro-segmentation, scope-based access enforcement
CC7 — System Operations	Anomaly detection, vulnerability exposure visibility, alerting
CC8 — Change Management	Policy workspace versioning, ADM drift detection
CC9 — Risk Mitigation	Vulnerability prioritization, compensating controls
A1 — Availability	Workload health monitoring, sensor telemetry
C1 — Confidentiality	PHI/PII zone isolation, encryption enforcement

2. SOC 2 Audit Preparation with CSW

2.1 Evidence Collection Timeline

SOC 2 Type II requires evidence across the **entire audit period**. Configure CSW from Day 1:

- Enable full flow telemetry retention (minimum 12 months)
- Enable policy workspace audit logging
- Schedule monthly vulnerability scan exports
- Configure alert export to SIEM for centralized evidence collection

2.2 Key Control Areas

CC6.1 — Logical Access Controls

- CSW enforces workload-level allowlist policies
- Every inbound connection to sensitive workloads requires explicit policy approval
- Policy violations logged with source, destination, process, and timestamp

CC6.6 — Network and Infrastructure Controls

- ADM documents communication paths visible to CSW over the selected observation window; corroborate coverage gaps with other discovery sources
- Micro-segmentation enforces least-privilege network access
- External access paths (third-party, partner) isolated in dedicated CSW scopes

CC6.7 — Transmission of Confidential Information

- CSW detects unencrypted transmission (HTTP, FTP, plain LDAP)
- Alerts trigger on any plaintext flow from confidential data scopes
- Encryption compliance report available for auditor evidence package

CC7.1 — Detection of Vulnerabilities

- Continuous vulnerability exposure / CVE inventory for CSW-instrumented workloads
- CVSS-scored reports with workload-level attribution
- Remediation tracking via policy compensating controls

CC7.2 — Monitoring of System Components

- Full process and network telemetry across all monitored workloads
- Anomaly detection alerts on baseline deviation
- Sensor health monitoring — alerts on agent offline events

CC7.3 — Evaluation of Security Events

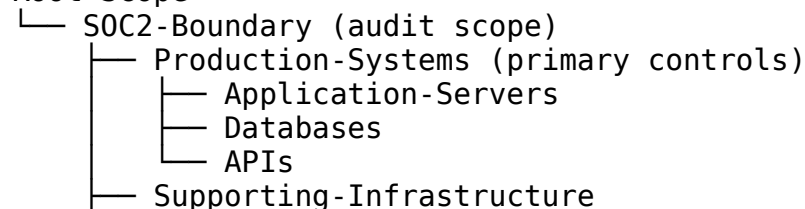
- Forensic telemetry supports security event investigation
 - Process-level audit trail: what ran, when, what it connected to
 - Flow search enables retrospective query across audit period
-

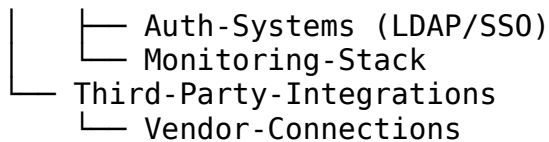
3. CSW Deployment for SOC 2

3.1 Scope Definition

Define CSW scopes aligned to SOC 2 system boundaries:

Root Scope





3.2 Policy Requirements per CC Control

CC Control	CSW Policy Requirement
CC6.1	Default-deny inbound to Production-Systems scope
CC6.6	Explicit allowlist for all inter-service communication
CC6.7	Block HTTP/FTP from Production-Systems; enforce HTTPS
CC7.1	Vulnerability scan enabled on all SOC2-Boundary workloads
CC7.2	Anomaly detection alert on all Production-Systems
CC8.1	Policy changes require approval workflow; audit logged

3.3 Continuous Monitoring Setup

CSW UI → Defend → Alerts

- New Alert Policy
- Scope: SOC2-Boundary
- Triggers:
 - Policy violation (any)
 - New vulnerability CVSS ≥ 7.0
 - Sensor offline > 5 minutes
 - Anomalous flow (ADM baseline deviation)
- Notify: SIEM webhook + email to security team

4. Evidence Package for SOC 2 Auditors

Evidence Item	CSW Source	CC Control	Frequency
Access control policy export	Defend → Policy Workspaces	CC6.1	Per audit request
Policy violation log	Alerts → Triggered Events	CC6.1, CC6.6	Monthly export
Vulnerability exposure report	Investigate → Vulnerability	CC7.1, CC9.1	Weekly
Network flow audit log	Investigate → Flow Search	CC6.7, CC7.2	Continuous
Anomaly alert log	Alerts →	CC7.2, CC7.3	Monthly

Evidence Item	CSW Source	CC Control	Frequency
	Dashboard		
ADM application map	Investigate → ADM	CC6.6, CC8.1	Quarterly
Sensor health report	Manage → Agents	CC7.2, A1.1	Monthly
Policy change audit trail	Policy workspace history	CC8.1	Per change

5. Common SOC 2 Audit Findings CSW Addresses

Auditor Finding	CSW Remediation
Undocumented network access paths	ADM generates observed dependency maps as evidence inputs
No workload-level access controls	Micro-segmentation enforces and logs all access
Undetected lateral movement	Anomaly detection + forensic telemetry
No evidence of encryption enforcement	Protocol-level flow analysis + block policy
Vulnerability management gaps	Continuous vulnerability exposure view with CVSS prioritization
Insufficient logging	Full process + network telemetry across audit period

Related Frameworks

- [ISO/IEC 27001:2022](#) — the international ISMS counterpart; many organisations pursue SOC 2 + ISO 27001 jointly.
- [NIST SP 800-53 Rev 5](#) — for cross-mapping CC-series criteria to a federal control catalogue.
- [NIST SP 800-207](#) — the ZTA pattern underneath CC6 logical access and CC7 system operations.

Replace [Customer Name] and bracketed fields before customer delivery.